

FUTURE INTERNS

CYBER SECURITY TASK 1

VULNERABILITY ASSESSMENT REPORT

Professional Read-Only Web Application Security Assessment

Target	demo.testfire.net
Security Tool	OWASP ZAP
Assessment Type	Passive / Read-Only
Evidence	OWASP ZAP alert screenshots
Report Date	31 August 2026

CONFIDENTIAL • TRAINING / ASSESSMENT USE

Assessment basis: supplied OWASP ZAP screenshots. This report does not claim that unobserved vulnerabilities were tested or confirmed.

1. Executive Summary

The supplied OWASP ZAP evidence identifies several web-application security weaknesses on **demo.testfire.net**. Eight alert categories are visible in the screenshots; five are documented in detail because supporting evidence was provided for them.

The principal remediation priorities are the reported absence of Anti-CSRF tokens and the missing Content Security Policy (CSP) header. Additional hardening is recommended for anti-clickjacking protection, session-cookie SameSite configuration, and server-version disclosure.

OWASP describes ZAP passive scanning as a safe process that observes messages without changing them. Therefore, the evidence is appropriate for a read-only assessment, but passive alerts should still be validated for exploitability and business impact before being treated as confirmed vulnerabilities. ■cite■turn0search3■

Overall assessment posture: **Medium remediation attention required**, with the highest practical priority assigned to CSRF protection and CSP.

2. Scope and Methodology

- Target shown in evidence: http://demo.testfire.net/
- Login endpoint shown for the CSRF finding: http://demo.testfire.net/login.jsp
- Tool evidenced: OWASP ZAP
- Testing represented: passive inspection of HTTP responses and HTML forms
- No destructive exploitation is represented by the supplied evidence
- Only findings visible in the supplied screenshots are documented as observations

Risk Overview

Medium Risk	2 findings	CSRF • CSP
Low Risk	2 findings	Server disclosure • SameSite
Medium Risk	1 finding	Anti-clickjacking

3. Vulnerability Summary

ID	Finding	ZAP Risk	Confidence	Priority
V-01	Server leaks version information via "Server" header	Low	High	Low
V-02	Absence of Anti-CSRF Tokens	Medium	Low	High
V-03	Content Security Policy (CSP) Header Not Set	Medium	High	High
V-04	Missing Anti-clickjacking Header	Medium	Medium	Medium
V-05	Cookie without SameSite Attribute	Low	Medium	Medium

Severity interpretation: the Risk and Confidence values above reproduce the ratings visible in the supplied ZAP screenshots. "Priority" is the report author's remediation order and is not a replacement for ZAP's risk rating.

4. Detailed Findings

V-01 – Server Leaks Version Information via "Server" HTTP Response Header

URL	http://demo.testfire.net/	ZAP Risk	Low
Confidence	High	CWE / WASC	CWE-497 / WASC-13
Evidence	Apache-Coyote/1.1		

Description

The HTTP response exposes server implementation/version information through the Server header. This can assist technology fingerprinting and help an attacker correlate the stack with known weaknesses.

Impact: Low direct impact; increases reconnaissance value.

Recommendation: Suppress detailed server/version information at the web server, application server or reverse proxy and keep the underlying platform patched.

Verification

Repeat the passive scan and inspect response headers to confirm detailed version information is no longer disclosed.

V-02 – Absence of Anti-CSRF Tokens

URL	http://demo.testfire.net/login.jsp	ZAP Risk	Medium
Confidence	Low	CWE / WASC	CWE-352 / WASC-9
Evidence	POST form using action="doLogin"		

Description

ZAP reports that no recognizable Anti-CSRF token was found in the HTML submission form. CSRF can cause an authenticated victim's browser to submit unintended requests. The screenshot explicitly marks this alert Low confidence, so manual validation is required.

Impact: Potential unauthorized state-changing actions, depending on session and application behavior.

Recommendation: Implement server-side CSRF protection for applicable state-changing requests using unpredictable session-bound tokens. OWASP recommends transmitting the token as a hidden form field or custom request header and validating it server-side. ■cite■turn0search5■

Verification

Confirm that a valid token is issued and required by the server, then repeat the ZAP assessment.

V-03 – Content Security Policy (CSP) Header Not Set

URL	http://demo.testfire.net/	ZAP Risk	Medium
Confidence	High	CWE / WASC	CWE-693 / WASC-15
Evidence	Content-Security-Policy header absent		

Description

The response does not set a Content-Security-Policy header. CSP is a browser-enforced defense-in-depth control that can reduce the impact of XSS and data-injection attacks. OWASP recommends delivering CSP through the HTTP response header. ■cite■turn0search1■turn0search0■

Impact: Reduced browser-side mitigation for client-side injection.

Recommendation: Deploy a restrictive CSP tailored to the application's legitimate resources. Avoid unnecessarily permissive directives such as unsafe-inline and unsafe-eval where practical.

Verification

Confirm Content-Security-Policy is present on relevant responses and test normal functionality.

V-04 – Missing Anti-clickjacking Header

URL	http://demo.testfire.net/	ZAP Risk	Medium
Confidence	Medium	CWE / WASC	CWE-1021 / WASC-15
Evidence	x-frame-options missing		

Description

ZAP reports missing anti-clickjacking protection. Without X-Frame-Options or an equivalent CSP frame-ancestors policy, HTML pages may be embeddable by another origin.

Impact: Potential clickjacking / UI redress against sensitive pages.

Recommendation: Prefer CSP frame-ancestors where supported and use X-Frame-Options such as DENY or SAMEORIGIN where appropriate. OWASP recommends these controls for preventing unauthorized framing.

■cite■turn0search4■turn0search0■

Verification

Inspect relevant responses and confirm the selected framing protection is present.

V-05 – Cookie without SameSite Attribute

URL	http://demo.testfire.net/	ZAP Risk	Low
Confidence	Medium	CWE / WASC	CWE-1275 / WASC-13
Evidence	Set-Cookie: JSESSIONID		

Description

The JSESSIONID session cookie is shown without a SameSite attribute. SameSite controls cookie transmission in cross-site contexts and provides defense in depth against CSRF.

Impact: Increased exposure to cross-site request scenarios when combined with other weaknesses.

Recommendation: Use SameSite=Lax or Strict where compatible. If SameSite=None is required, use Secure and retain robust CSRF protection. OWASP notes that SameSite is defense in depth and does not generally replace proper CSRF defenses. ■cite■turn0search5■

Verification

Inspect Set-Cookie and confirm the intended SameSite, Secure and HttpOnly settings.

5. Evidence – OWASP ZAP Screenshots

The following screenshots were supplied as evidence. They are reproduced without substantive modification. The screenshots show ZAP's alert names, URLs, risk/confidence values and evidence fields.

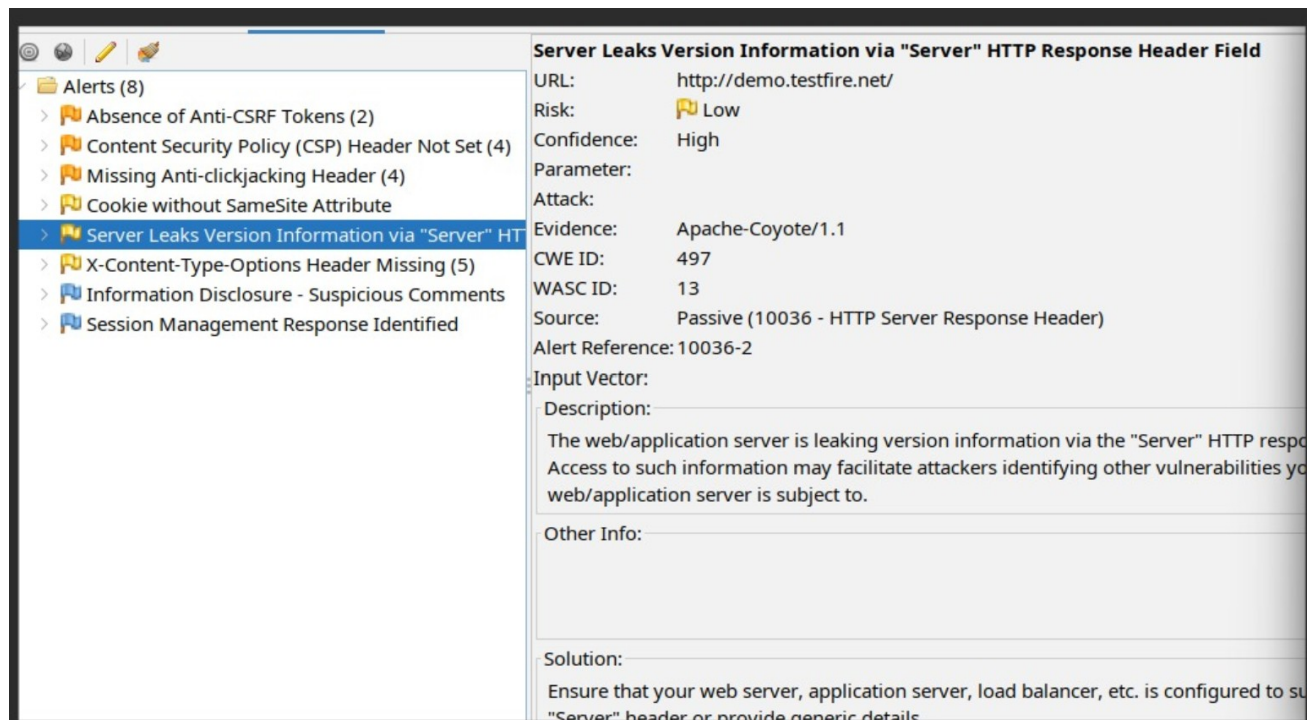


Figure 1 – Server version information disclosure

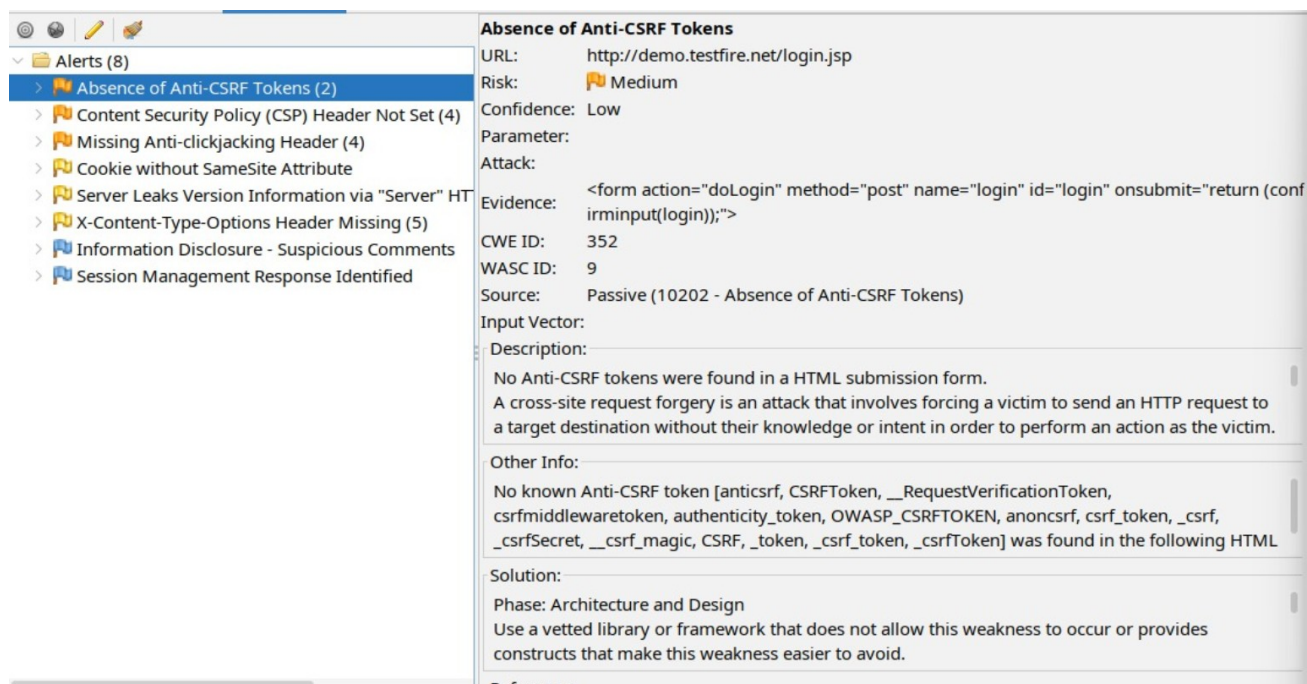


Figure 2 – Absence of Anti-CSRF Tokens

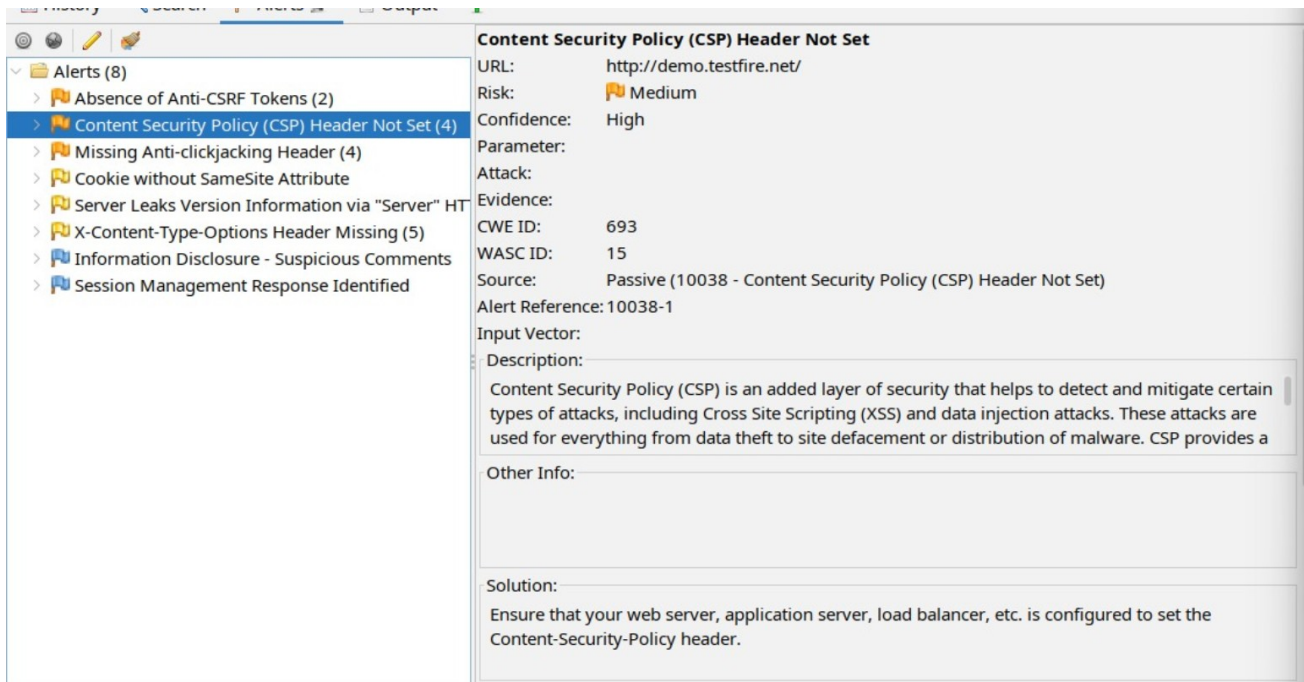


Figure 3 – Content Security Policy Header Not Set

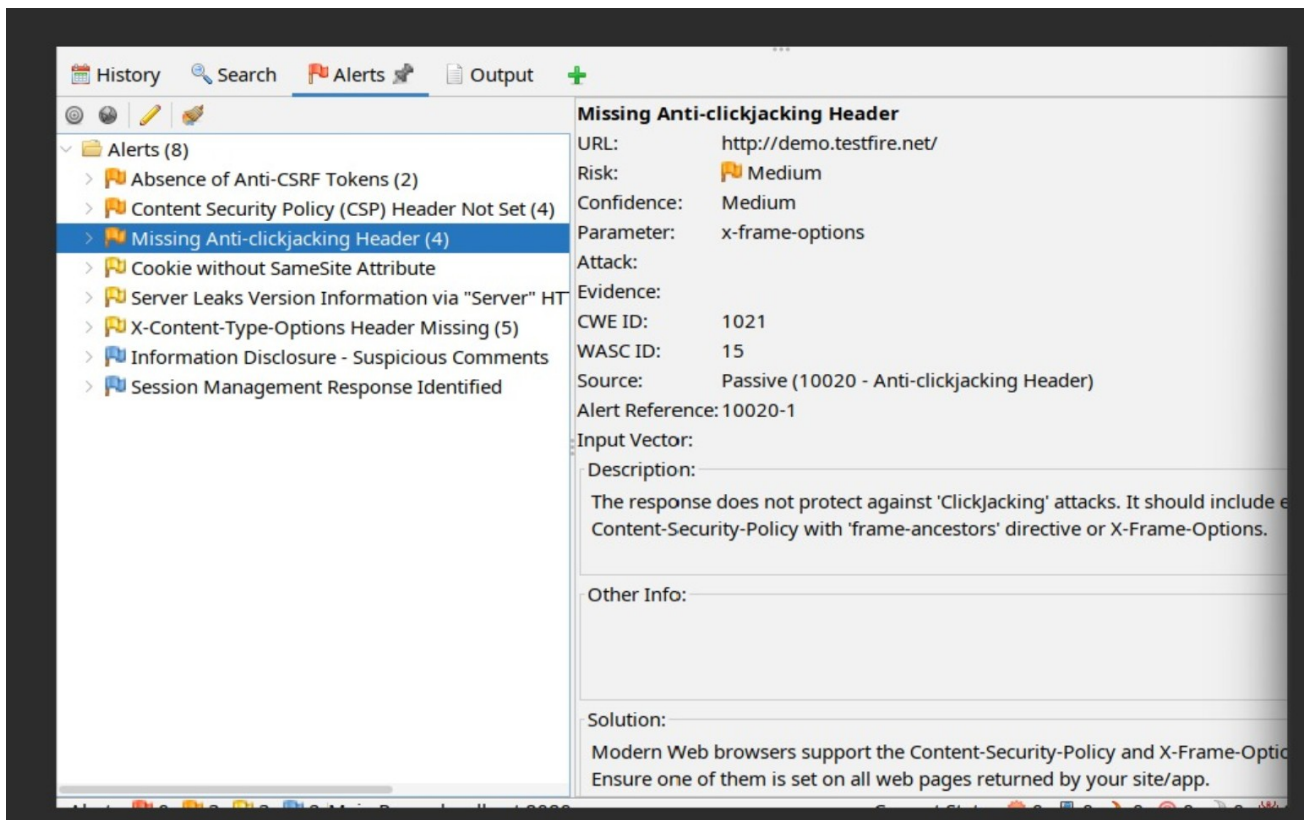


Figure 4 – Missing Anti-clickjacking Header

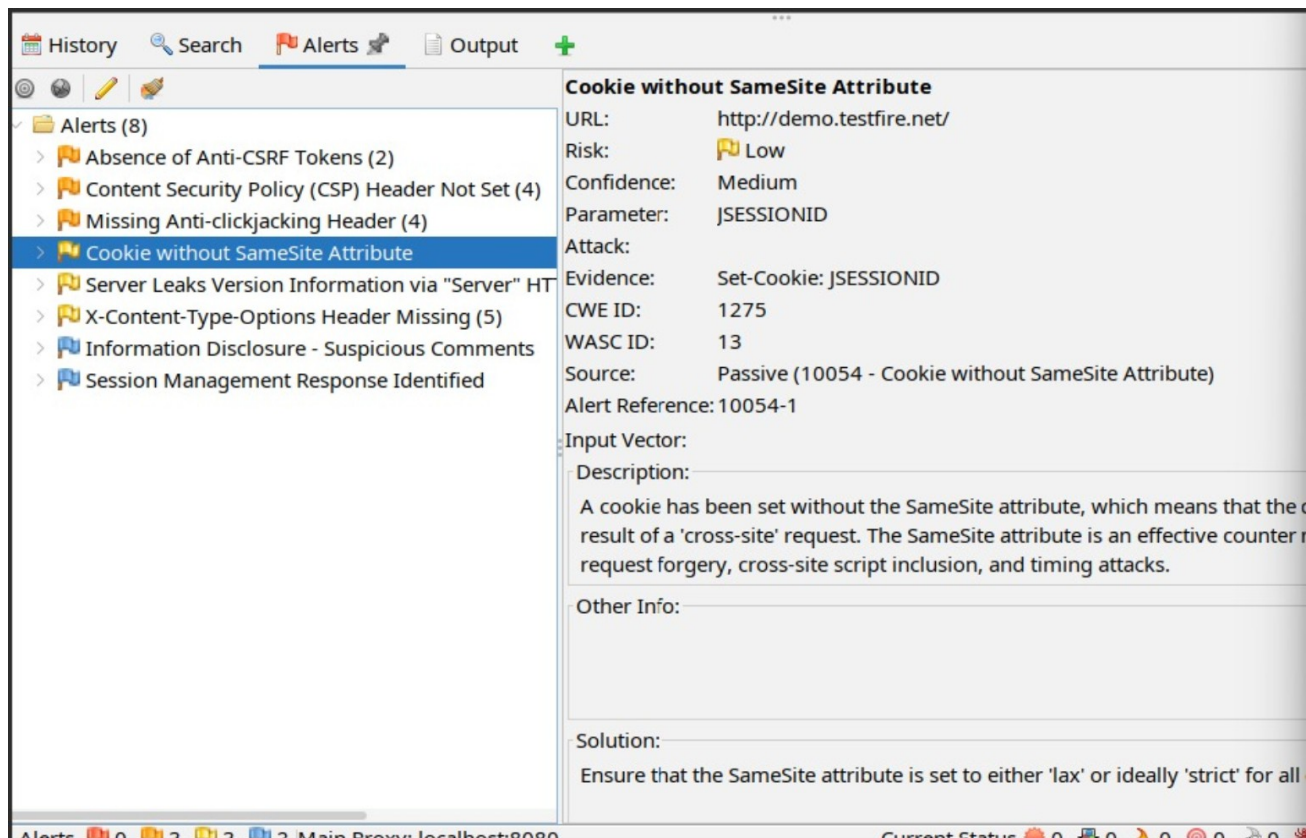


Figure 5 – Cookie without SameSite Attribute

6. Remediation Plan

Priority 1 – Application request protection: Implement and validate CSRF protection on state-changing operations. Use framework-supported controls where available. ■cite■turn0search5■

Priority 2 – Browser-side defense in depth: Deploy a restrictive CSP and tune it against legitimate application resources. CSP should be delivered as an HTTP response header. ■cite■turn0search1■

Priority 3 – Clickjacking protection: Add CSP frame-ancestors and/or X-Frame-Options according to the application's framing requirements. ■cite■turn0search4■

Priority 4 – Session cookie hardening: Configure SameSite appropriately and use Secure/HttpOnly for sensitive session cookies where applicable. SameSite should complement, not replace, CSRF protection. ■cite■turn0search5■

Priority 5 – Reduce information disclosure: Remove detailed product/version information from Server headers while maintaining normal server operation.

Recommended security-header baseline

Control	Recommended direction	Purpose
Content-Security-Policy	Restrictive policy; use frame-ancestors where applicable	Defense in depth against XSS/injection and framing
X-Frame-Options	DENY or SAMEORIGIN where appropriate	Clickjacking protection
Set-Cookie	SameSite=Lax/Strict as compatible; Secure; HttpOnly	Session/cross-site request hardening
Server	Avoid detailed version disclosure	Reduce reconnaissance value

OWASP's HTTP Headers guidance notes that security response headers can help mitigate issues including clickjacking, XSS-related attacks and information disclosure. ■cite■turn0search0■

7. Retest Checklist

- Confirm CSRF tokens are present on applicable state-changing forms and are enforced server-side.
- Confirm Content-Security-Policy is returned on relevant HTML responses and is appropriately restrictive.
- Confirm anti-clickjacking protection is present through CSP frame-ancestors and/or X-Frame-Options.
- Confirm JSESSIONID and other sensitive cookies have appropriate SameSite, Secure and HttpOnly attributes.
- Confirm detailed server/version information is no longer disclosed in response headers.
- Run OWASP ZAP again and compare the resulting alert set with the baseline.
- Manually validate any remaining low-confidence alerts before classifying them as confirmed vulnerabilities.

8. Limitations

- This report is based on the five supplied screenshots rather than a fresh scan performed while preparing the report.
- Eight ZAP alert categories are visible in the screenshots, but detailed evidence was supplied for five categories.
- Passive alerts indicate potential weaknesses; they do not independently establish exploitability or business impact.
- The CSRF alert is explicitly marked Low confidence in the supplied screenshot and should be manually validated.
- No conclusion is made about vulnerabilities not visible in the supplied evidence.

9. Conclusion

The supplied evidence indicates several web-security hardening gaps in demo.testfire.net. The strongest remediation focus should be CSRF protection and CSP, followed by clickjacking protection and session-cookie hardening. Server fingerprinting information should also be minimized. After remediation, a complete ZAP retest and targeted manual validation should be performed.

Assessment Status: Remediation Recommended

Evidence Basis: OWASP ZAP screenshots supplied by the assessor

Prepared for: Future Interns – Cyber Security Task 1